

Privacy and Cybersecurity Protection Policy

1. Introduction

Charidy Inc. is committed to ensuring the privacy and security of all data collected, processed, and stored within its infrastructure. This Privacy and Cybersecurity Protection Policy outlines the measures and procedures we employ to protect sensitive data, including payment card information, and maintain compliance with the Payment Card Industry Data Security Standard (PCI DSS) at Level 3.

2. Scope

This policy applies to all employees, contractors, vendors, and any other parties with access to sensitive data and resources hosted on AWS infrastructure.

3. Data Classification

We classify data into different categories based on its sensitivity and impact on the organization's security posture. The data classification levels are:

- a. Highly Sensitive Data: This includes payment card information, personally identifiable information (PII), and any other data that could cause severe harm if compromised.
- b. Sensitive Data: Non-public business-related information that requires protection from unauthorized access.
- c. Public Data: Information intended for public dissemination and doesn't contain sensitive or personal information.

4. AWS Security

- a. We acknowledge that AWS provides a secure cloud infrastructure. We will follow AWS best practices for security and ensure that all our AWS configurations adhere to industry standards.
- b. Regularly review and assess the security of AWS resources through vulnerability assessments and penetration testing.
- c. Enable encryption at rest and in transit for all sensitive data stored within AWS services.
- d. Implement access controls, ensuring least privilege principles are followed, and regularly review and revoke unnecessary access rights.

e. Regularly monitor AWS logs and review security alerts to detect and respond to security incidents promptly.

5. PCI DSS Compliance

a. As a Level 3 PCI DSS compliant organization, we will maintain compliance with all relevant requirements outlined in the PCI DSS standard.

b. Conduct annual PCI DSS assessments and audits to ensure ongoing compliance.

c. Regularly update and patch all systems and applications used for payment processing.

d. Limit access to payment card data to only authorized personnel with a legitimate business need.

e. Encrypt transmission of payment card data across open, public networks.

f. Maintain an information security policy and conduct regular training and awareness programs for all employees handling payment card data.

6. Data Handling and Retention

a. Access to sensitive data must be restricted to authorized personnel only, and access logs must be regularly reviewed.

b. All data handling, processing, and storage must be done following industry best practices and regulatory requirements.

c. Data retention periods must comply with legal and regulatory requirements and be regularly reviewed and updated.

7. Incident Response

a. Establish an incident response plan that outlines procedures for identifying, reporting, and responding to security incidents.

b. Report security incidents to the relevant authorities and affected parties, as required by law or contractual obligations.

c. Conduct post-incident analysis to identify root causes and implement measures to prevent similar incidents in the future.

8. Third-Party Compliance

- a. Ensure that third-party service providers and vendors handling sensitive data adhere to similar privacy and security standards.
- b. Regularly assess third-party compliance with security and privacy requirements.

9. Employee Responsibilities

- a. All employees must undergo regular cybersecurity awareness training and adhere to the organization's security policies.
- b. Employees must report any suspected security incidents or policy violations promptly.
- c. Employees must follow data handling procedures, especially when dealing with sensitive information.

10. Policy Review and Updates

This policy will be reviewed at least annually or whenever significant changes occur within the organization's infrastructure, technology, or regulations.

By implementing and adhering to this Privacy and Cybersecurity Protection Policy, Charidy Inc. aims to create a secure environment for sensitive data, maintain PCI DSS Level 3 compliance, and protect the privacy of our customers and stakeholders.